SCHOOL: STRATHMORE UNIVERSITY

FACULTY: SCES

COURSE: CNS

ADMISSION NUMBER: 192224

NAME: MALCOLM JOHN NEZEREAB

UNIT: ETHICAL HACKING

Date: 23rd September, 2026

EXECUTIVE SUMMARY

This report contains the results of preliminary reconnaissance and attack surface assessment that were conducted against a legacy Linux server of AfriLink Digital Services Ltd., simulated in the lab environment through a Metasploitable 2 (10.0.3.3). This assessment was carried out according to the Rules of Engagement document for this engagement and was limited solely to footprinting, enumeration and fingerprinting – no exploitation or access to the systems was performed.

It was established that the target can be reached through the same local network segment as the assessment machine and there was no filtering at the network layer between them. As the result of complete port scanning, 29 open TCP ports have been found and they provided the following services: file transfer, remote access, database, file sharing and web services. Three important findings can be highlighted as follows: unauthenticated root-level bindshell on port 1524, vulnerable version of vsftpd (port 21) which has publicly disclosed backdoor, and vulnerable version of UnrealIRCd (port 6667) which is also known to have a backdoor. Other findings include unsecured Telnet service, outdated version of Apache, PHP and Samba and several intentionally vulnerable web applications (DVWA, Mutillidae, TWiki, phpMyAdmin) which can be accessed freely without any restrictions, some of them have default credentials disclosed publicly.

Overall these findings demonstrate considerable attack surface due to the use of old unpatched software but not because of one single mistake. It is suggested that AfriLink should consider finding a bindshell on port 1524 as a potential breach and give priority to patching or removal of vsftpd and UnrealIRCd services, turn off legacy unsecured protocols and use the existing SSH service, as well as changing default credentials..

Chapter 1: Rules of Engagement

1.1 Assessment Purpose

The penetration testing engagement is meant to determine the possible points of exploitation that an attacker may use to gain access to AfriLink's information

1.2 Objectives

The assessment aims to determine the reachability of the target system, the network information that can be obtained, enumerate the number of exposed ports, discover the operating services that may act as a point of vulnerability, identify the technologies and versions being used by the system. Additionally, it aims to find the exposed operating system information, determine the exposed web services and applications along with the information disclosed by those services. Finally, the assessment intends to consolidate the findings and suggest the possible security improvements based on the findings.

1.3 Authorized Target

The authorized target is the company's Legacy Linux server which is metasploitable 2.

1.4 Scope

Within the assessment, only the company's legacy server will be used as a point of assessment through passive and active foot printing whereby aspects such as open ports discovery, dns lookups, disclosed operating system information and information disclosed by exposed services and applications are the boundaries within which the assessment will be conducted.

1.5 Out-of-Scope Assets

Systems such as other legacy devices holding past customer data, will not be assessed or tested. The devices within or outside the same subnet as the legacy linux server will not be assessed. Additionally, systems of other organizations that make use of Afrilink Digital Services will not be used for testing.

1.6 Permitted Activities

Host discovery e.g using ping sweep.

Dns lookups

Port scanning to discover open ports

Operating system fingerprinting

Services and their versions discovery (banner grabbing)

Web service and application discovery

Viewing web headers and viewing pages to discover information disclosed.

Enumeration of exposed services which is limited to observation e.g through listing shares to check for shared files or folders on the network.

1.7 Prohibited Activities

Exploitation of vulnerable services and ports.

Privilege escalations e.g changing one's rights to be admin

Brute forcing into the system e.g to access the confidential information.

Assessing other systems or trying to attack other systems.

Exploitation of user accounts using information from databases or remote-access services.

Modifying files or creating accounts.

1.8 Testing Window

The assessment will be carried out between 2am and 4am on Friday the 18th of September 2026.

1.9 Communication and Escalation

In the event of unexpected problems that may arise during the assessment, the problems shall be documented and sent to the organisation awaiting further guidance to avoid independent decisions from being made.

1.10 Safety and Operational Considerations

The testing will carry out non-intrusive scans and non-aggressive techniques to prevent system crashes. Additionally, the testing will be carried out in the very early hours of the day to ensure no service disruptions arise in the event of issues during testing assuming most customers will not be actively engaging with the system at that time.

1.11 Data Handling

All screenshots taken during testing will be put into a single folder called Pen_Test_1 and this folder shall be transferred to the organisation using a flash disk to avoid sending the information over the network. Once the organization receives the files, all logs and information shall be deleted off the computer of the penetration tester. Any credentials or information discovered shall

only be recorded as a finding and shall not be used elsewhere. Additionally, the penetration tester shall be bound by the non-disclosure agreement.

1.12 Evidence collected and Documented

All screenshots taken shall be referenced using the word figure. Also, each necessary screenshot shall have a brief explanation on its significance in terms of security.

1.13 Stop Conditions

Testing will immediately stop if the target becomes unreachable, or if the assessment begins to head out of scope for example, a case where another host is accessed accidentally or even any case that ends up carrying out activities beyond what was defined in the permitted activities.

1.14 Authorization

The assessment is authorised by AfriLink Digital services and their representative Mr Elisha Edwin is responsible for the Legacy Linux Server.

1.15 Rules for Third Party Systems

The assessment must not attempt to scan or access any information regarding external organizations. In addition, any logged evidence in the evidence logs shall be sent along with data on external systems accidentally discovered during assessment shall be communicated immediately to Mr Edwin Elisha.

Chapter 2: ASSESSMENT PLANNING AND TARGET IDENTIFICATION

This assessment was done in an isolated laboratory environment without any connection to a live production environment. The laboratory environment had two virtual machines running on Oracle Virtual Box; the Kali Linux assessment machine (10.0.3.13/24), where all recon tasks were performed, and the Metasploitable 2 virtual machine (10.0.3.3/24) acting as the authorized target, portraying the legacy Linux server of AfriLink Digital Services Ltd. Both virtual machines were on the same local network (10.0.3.0/24), without any routing and/or filtering device in between them as stated in Chapter 3. The Kali Linux machine had typical reconnaissance tools such as Nmap, curl and web browser; all these tools were tested to ensure that they were operational before carrying out the tasks (figure 2.5). This laboratory environment ensured that all the tasks done in the assessment process were not a danger to any other network/system outside of the lab.

2.1 Target Verification

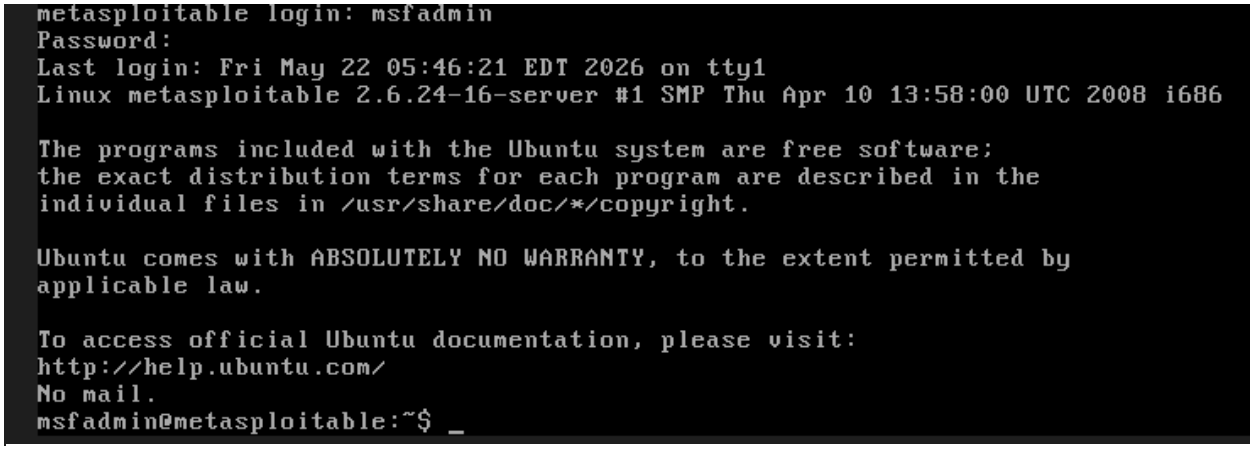


Figure 2.1 Target machine booted up

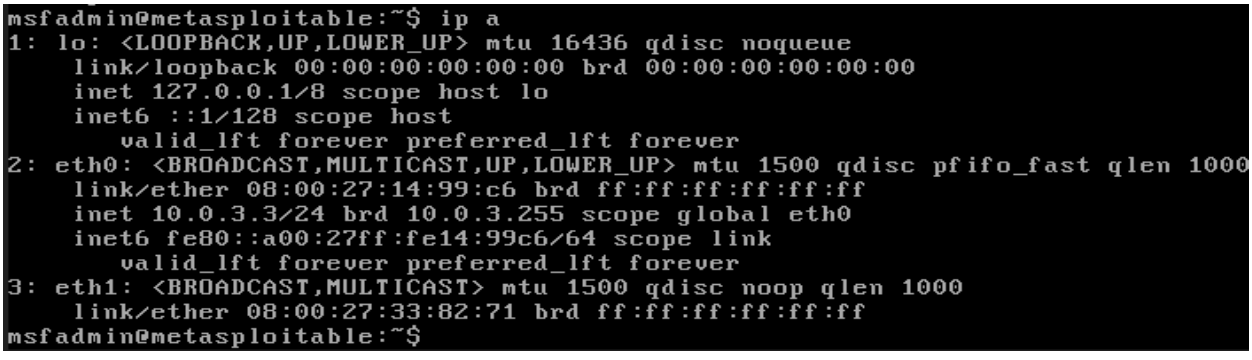


Figure 2.2 Target's IP

The target identity was established direct access to the assigned virtual machine as shown in figure 2.1. The system's login banner and shell prompt both displayed metasploitable and the

kernel string confirmed a Linux 2.6.24 environment which is consistent with the authorized Target machine mentioned in the rules of engagement. The host's IP address was confirmed as 10.0.3.3/24 using the ip a command as shown in figure 2.2.

2.2 Network Verification

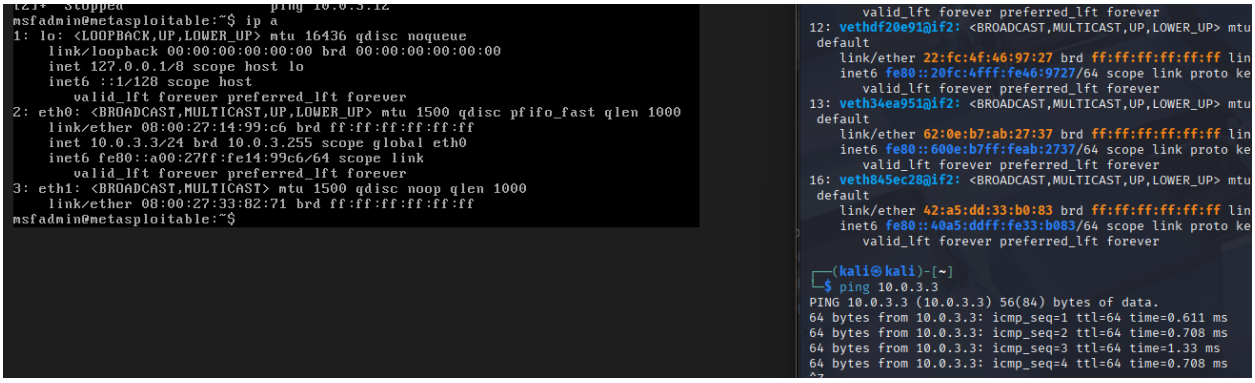


Figure 2.3 Pinging from kali to the target machine



Figure 2.4 The target machine and kali are on the same subnet

The assessment machine was confirmed to reside on the IP 10.0.3.13/24 within the 10.0.3.0/24 subnet which is the same network segment as the target which is on 10.0.3.3/24 as shown in figure 2.4. A further confirmation of connectivity was carried out using the ping command showing that indeed the kali machine could reach the target machine. This shows direct access to the target.

2.3 Assessment Readiness

Both machines booted as expected. The target machine took 2-3 minutes to boot up with no issues and only required one to input the login credentials. The target could be reached via a ping as shown in figure 2.3 and 2.4. After checking for tool readiness, it was confirmed that scanning tools such as nmap were readily available as shown in figure 2.5.



Figure 2.5 Nmap version

No issues were encountered during booting up as both booted up normally. All actions carried out such as a ping test remained within the defined boundaries of the rules of engagement.

Chapter 3: Network Foot printing

3.1 Reachability

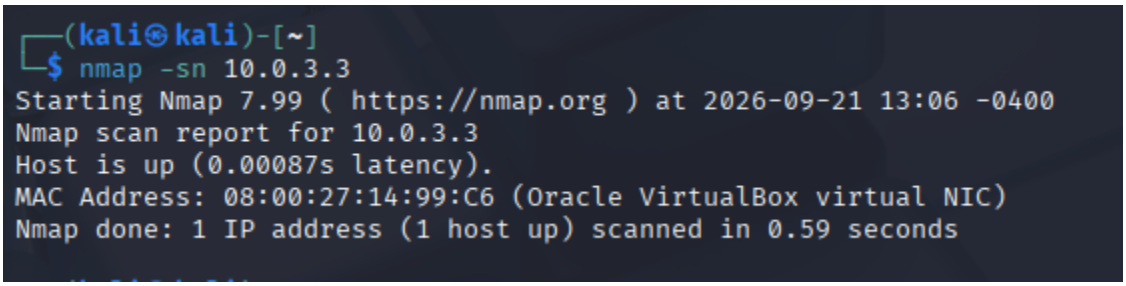


Figure 3.1 Testing host reachability

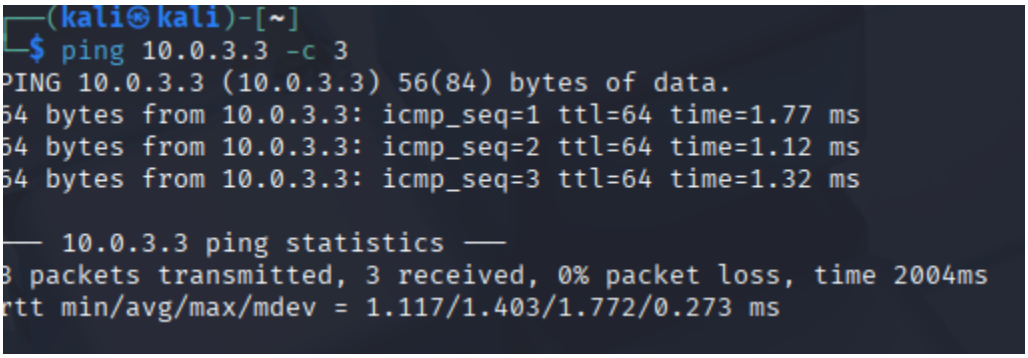


Figure 3.2 Ping Test on the host

An Nmap host discovery scan was carried out using the -sn flag which ensures no ports are scanned but it does more like a ping scan to check if the host is up as shown in Figure 3.1. The second test on network reachability was pinging the target device using a count of 3 packets using the -c flag in ping as seen in figure 3.2. From the ping, it is also evident that the target was reachable over zero hops since it has a constant TTL (Time to live) 64 meaning that it crossed 0 routers thus demonstrating that the assessment was certainly being carried out in a controlled set up. The target's response to both probes confirmed that it was live and reachable.

3.2 Network Information

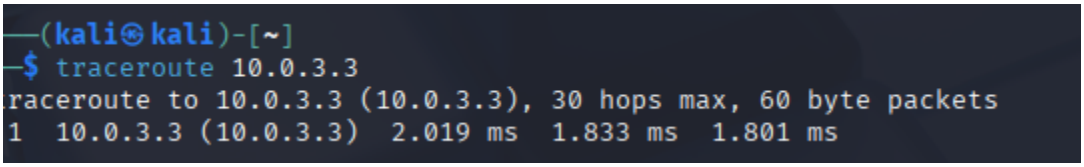


Figure 3.3 Network Traceroute

After carrying out a traceroute to the target machine, a single hop was discovered, this indicated that there was only a single response point whereby the destination was the first and only responder thus indicating that there was a direct unrouted local connection as shown in Figure 3.3 showing the distance from the kali machine to the target machine on a network. This aligns with the zero hops shown by the ping carried out in Figure 3.2 which showed that the packet did not traverse across routers. Regarding security, this indicates that there is no network layer device to filter or route traffic between machines. When it comes to enumeration and scanning, results will rarely be distorted or blocked by intermediate filtering and this makes reconnaissance easier for a tester or attacker as they would not need to bypass any network layer device to reach the target directly.

3.3 Host Identification

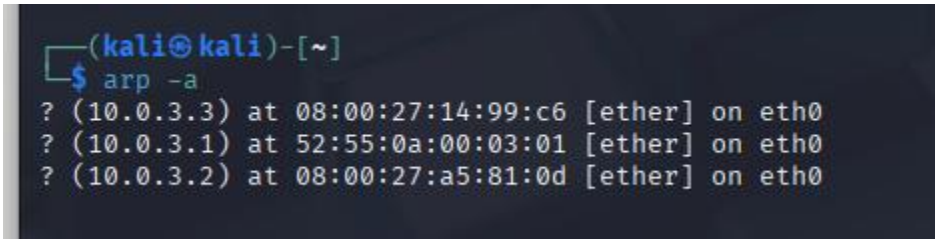


Figure 3.4 Checking the ARP table for learned Mac addresses

After running the arp -a command on the kali machine, a list of MAC addresses and Ips learned for devices on the network are displayed as shown in Figure 3.4 using the Ip of the target machine to map onto its MAC address. Other hosts were also discovered during the running of the command however; they were not assessed during this assessment as per the boundaries defined in the rules of engagement. Using the MAC address, the target is uniquely identified on a network. To determine the vendor, an nmap -sn command was executed and it revealed that the vendor was Oracle VirtualBox virtual NIC as seen in Figure 3.5

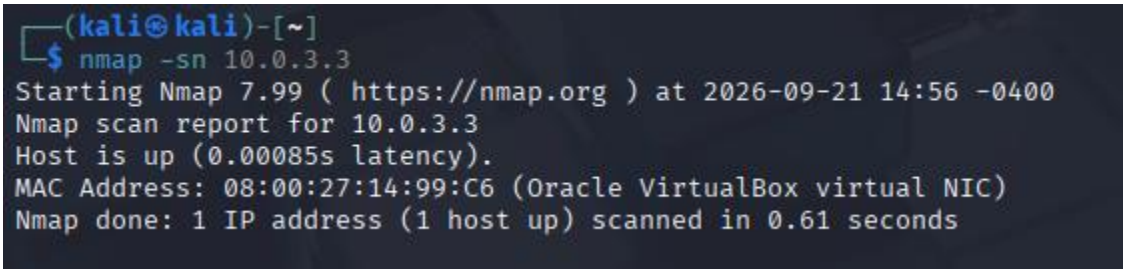


Figure 3.5 NIC vendor information

3.4 Interpretation

From the information gained from the sections 3.1-3.3, the information assists a tester or an attacker to confidently carry out port and service enumeration. For example, knowing the targets reachability, allows for one to scan the ports since the machine is live and visible on the network. Additionally, the lack of filtering would prevent a tester's traffic from being discarded or delayed thus allowing multiple requests to be sent reliably which would improve the accuracy of the attained results. In addition, knowledge of the specific MAC address allows a tester to avoid carrying out tests on the wrong system accidentally thus enabling the tester to remain within the boundaries defined in the rules of engagement.

Chapter 4: PORT AND SERVICE ENUMERARION

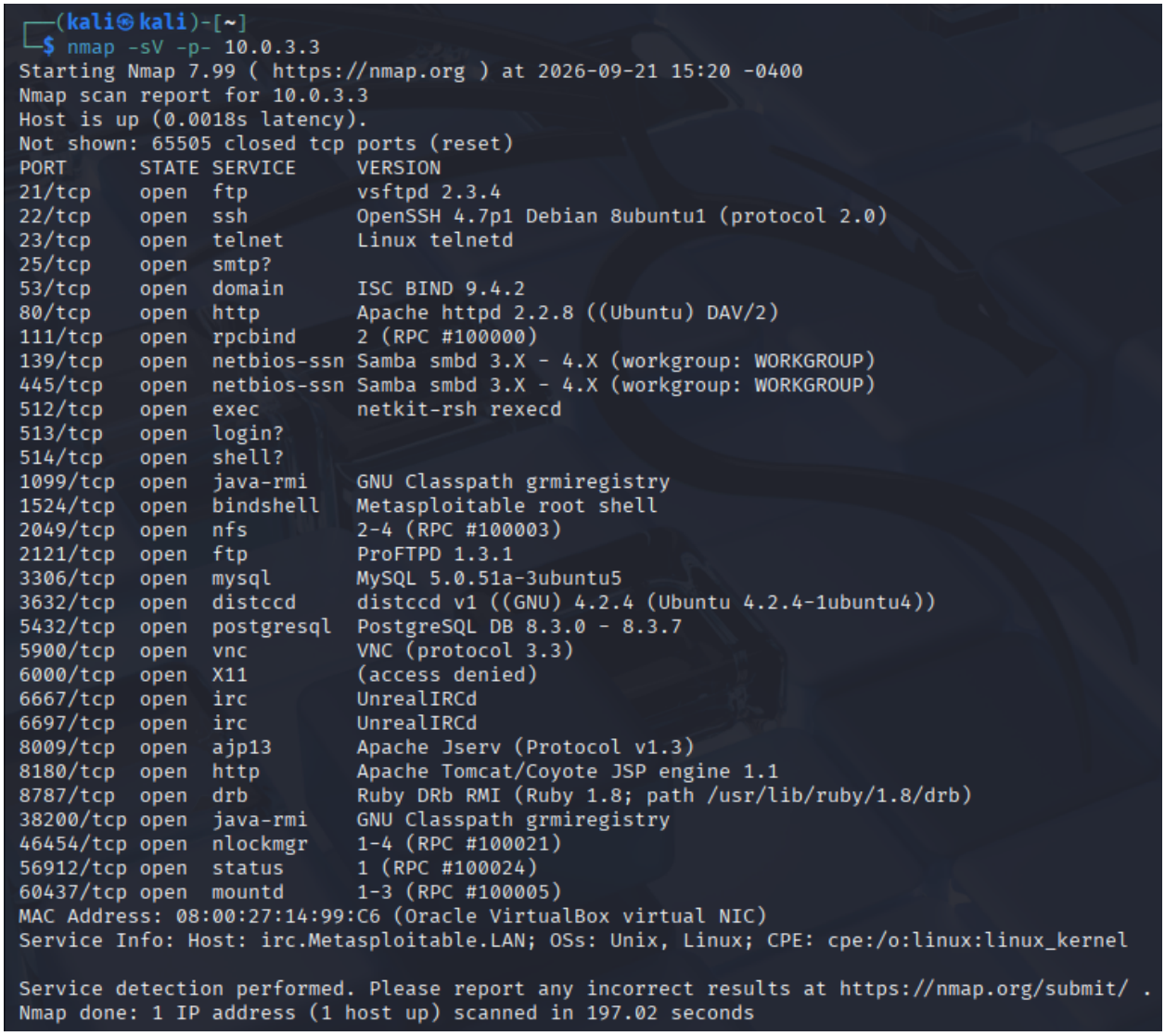


Figure 4.1 Port scanning and services enumeration

Table 4.1 Service Inventory table

Port	Protocol	Service	Version	Purpose	Information Disclosed	Security Significance
21	tcp	ftp	Vsftpd 2.3.4	Used for file transfer	Software name and its version	Has a known backdoor vulnerability (CVE-2011-2523) allowing remote root access
22	tcp	Ssh	Openssh 4.7p1 Debian 8ubuntu1 protocol 2.0	Used for secure remote login	Exact software, version, OS and protocol	Encrypted, but an oldversion thus was affected by ssh vulnerabilities
23	tcp	telnet	Linux telnetd	Used for unencrypted remote login	Confirms that telnet is running meaning information is unencrypted	Transmits all data including credentials in plaintext thus allowing sniffing
25	tcp	Smtp	?	Used for mail transfer	Service is up and responsive.	The question mark shows unconfirmed version limits thus mail services could be abused for spoofing if misconfigured
53	tcp	Dns	ISC BIND 9.4.2	Used to translate domain names into ip addresses	Exact software and version i.e ISC BIND 9.4.2 respecitvely	Old Bind version which has DNS related CVEs such as cache poisoning and DoS

80	tcp	http	Apache httpd 2.2.2.8	Used to serve unencrypted web content	Exact software and version	Outdated Apache version which allowed file manipulation if misconfigured
111	tcp	Rpcbind	2 RPC #100003	Maps RPC(Remote Procedure Call) program numbers to the network port they're running on.	RPC program number and version info	Exposes RPC service directory thus allowing anyone to discover other RPC services such as NFS
139/445	tcp	Netbios-ssn	Samba smbd 3.x -4.X	Provides file and printer sharing over a network especially in Unic systems	Exact software and version range	The older versions of samba contain remote code execution vulnerabilities e.g usermap script i.e CVE-2007-2447
512	tcp	Exec	Netkit-rsh rexecd	Allow remote command execution and remote login	Confirms legacy r-services stack present	Legacy protocols with weak/no authentication and no encryption
513	tcp	Login	-	Same as exec	Same as exec	Same as exec
514	tcp	Shell	-	Same as exec	Same as exec	Same as exec
1099/38200	tcp	Java-rmi	GNU Classpath registry	Enables a program running on one machine to invoke objects/methods on another machine.	Confirms GNU Classpath grmiregistry	Vulnerable to insecure seserialization attacks thus allowing remote code execution

1524	tcp	Bindshell	Metasploitable root shell	Not a legitimate service as it acts as a backdoor providing direct root shell access with no authentication	Indicates that an unauthenticated root access exists on the port	A rootshell backdoor requiring no authentication allows unauthenticated root access
2049	tcp	nfs	2-4 (RPC #10003)	File sharing over the network	RPC program and version confirms nfs being active	Heavily relies on IP based trust this if misconfigured, exports can expose sensitive files
2121	tcp	ftp	ProFTPD 1.3.1	File sharing	Exact software and version	This version of ProFTPD has a known backdoor vulnerability CVE-2010-4221
3306	tcp	Mysql	MySql 5.0.51a	Database service that allows client applications to connect to the MySQL database engine running.	Exact software and Version	Database exposure to the network can lead to loss of credentials
3632	tcp	distccd	Distccd v1 gnu 4.2.4	A network daemon for distributing compiler workloads across machines	Exact software and version	Has a known remote code execution vulnerability when exposed without access restriction CVE-2004-2687

5432	tcp	Postgresql	Postgresql DB 8.3.0-8.3.7	A database service for storing	Exact software and version range	Suffers sensitive data exposure especially when misconfigured
5900	tcp	Vnc	Vnc protocol 3.3	Remote desktop sharing access thus letting a user view and control the machine's GUI remotely	Protocol version is disclosed	Has weak authentication thus remote GUI access if compromised provides full control
6000	tcp	X11	Access denied	-	Access is restricted although the service is running	If misconfigured, exposure can allow screen/input capture
6667/6697	tcp	Irc	UnrealIRCD	Internet Relay Chat server	Exact software being used	Has a backdoor i.e CVE-2010-2075 that enables remote command execution
8009	tcp	Ajp13	Apache Jserv protool	Proxies requests efficiently between a front facing web server and java application server	Protocol version	External exposure of this leads to a vulnerability that would allow an attacker to carry out a Ghostcat-style file read
8180	tcp	http	Apache Tomcat	Used to serve unencrypted web content	Exact software and version	Outdated version hence weak credentials on the

						manager interface
8787	tcp	Drb	Ruby DRb RMI	Allows a Ruby program to call methods on objects running in a different Ruby process potentially on a remote machine.	Exact programming language and version	No built in authenticatio n thus the possibility of remote code arises
46454	tcp	nlockmg r	1-4 RP(#100021)	Manages file locking for nfs	RPC program and version numbers confirming NFS support	Supports the file sharing service's rrisk profile
56912	tcp	status	1 (RPC # 100024)	Tracks status of the Nfs clients so that file locks can be properly cleared	RPC program and version numbers confirming NFS support	Similar to nlockmg
60437	tcp	mountd	1-3 RPC #100005)	Nfs daemon that handles client requests to mount an exported NFS directory,	RPC program and version numbers confirming NFS support	Similar statusto

4.1 Port Exposure

A full port scan was carried out using nmap -sV -p- which identified 29 open TCP ports on the target detailed in in the service inventory table Table4.1.

4.2 Service Identification

The running services on each open port were identified via the version detection flag in nmap ranging from services like SSH to backdoor services left intentionally open as seen in Table 4.1

4.3 Version Identification

Version information was successfully obtained for most of the services as indicated in Table 4.1, however a key finding was that services such as SMTP showed a question mark indicating unconfirmed version data and x11 indicated access denied

4.4 Service Analysis

Port 21 runs ftp with vsftpd 2.3.4 version which contains a backdoor vulnerability that allows unauthenticated remote access. Port 23 runs Telnet, which transmits credentials and data in the form of plain text which allows packet sniffing to be carried out. Port 80 runs the Apache HTTP Server which serves the unencrypted web application content. Ports 512-514 run the r-services suite i.e exec, login and shell, which offer remote access with weak or no authentication along with no encryption. Port 1524 hosts an unauthenticated version of bindshell which is identified by Metasploitable root shell thus representing direct root level access with no authentication barrier. Port 3306 runs MySQL and port 5432 runs PostgreSQL, these two expose database services to the network which can lead to credentials being stolen. Port 139/445 run Samba, which is a file sharing service of which its older versions had remote code execution vulnerabilities. Port 6667 runs UnreallRCD, a software with a backdoor vulnerability. Port 8180 runs Apache Tomcat which hosts a secondary Java-web based platform.

4.5 Attack-Surface Interpretation

The combined exposere of multiple services significantly widens the target's attack surface. The presence of multiple outdated and backdoored services such as vsftpd, UnreallRCd and the bindshell, mean that an attacker has several points to compromise rather than one i.e if one gets pacthed then there are still other points of entry. In addition, the coexistence of file sharing e.g Samba,NFS, creates the possibility of stealing of credentials being shared over the network or even modification of files, databases such as MySQL and PostgreSQL provide an attacker with the opportunity to steal credentials, remote access services such as SSH – the old version which allowed attackers to run and execute malicious code with root privileges, telnet which transmits data in plaintext allowing a man in the middle attack to be carried out. These overall increase the potential impact of any single compromise. This kind of layered exposure is what broadens the attack surface due to accumulated services that have not undergone a regular security review.

4.6 Security Distinction

An exposed port is a port that is open and accepting connections e.g port 23 is open, this does not reveal what is running assuming one does not know the service running on that port. An identifiable service is a port for which the running software has been determined e.g port 3306 runs MySQL. A potentially vulnerable service is one where the software and version is known to have vulnerabilities e.g vsftpd 2.3.4 is a associated with a known CVE of having a backdoor for

unauthenticated remote access. A confirmed vulnerability needs active verification that the specific suspected vulnerability is indeed present and exploitable.

Chapter 5: OS FINGERPRINTING

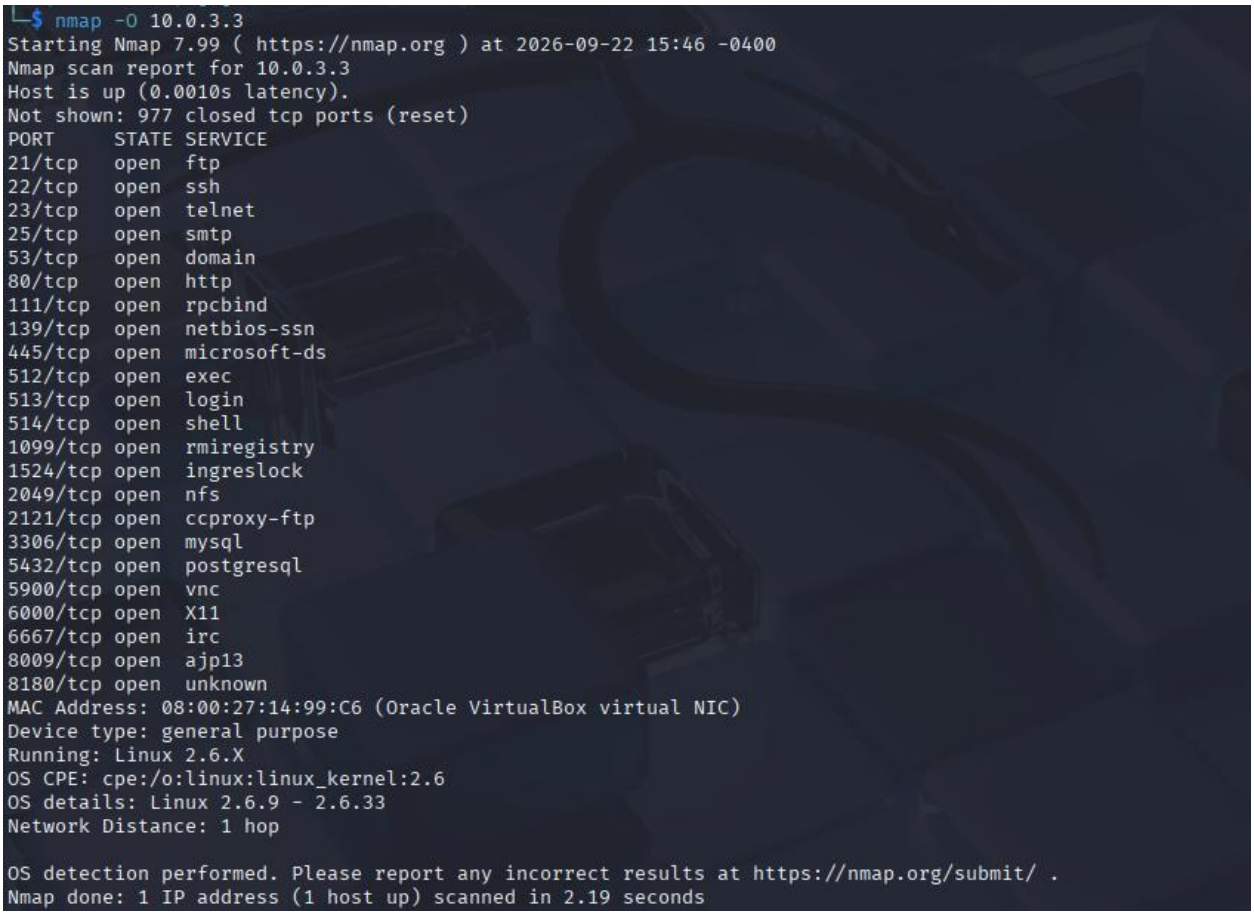


Figure 5.1 OS Information

5.1 Evidence Classification

Table 5.1 Evidence table

Category	Finding	Evidence	Classification	Why
OS Family	Linux	"Running Linux 2.6.X" in figure 5.1	Inferred	Nmap matched the target's response pattern against its fingerprint database rather than doing a direct read off the host

Version/release	Linux kernel 2.6.9-2.6.33	"OS details Linux 2.6.9-2.6.33" in figure 5.1	Inferred	A range is provided rather than a confirmed exact version
Host characteristics	General-purpose device; VirtualBox virtual NIC	Device type line and Mac address line in figure 5.1	Observed	MAC address and NIC vendor were read directly from the network hardware data.
Network stack characteristics	OS guess derived from TCP/IP response behaviour e.g TTL	Nmap- O methodology and for TTL from pings in Figure 3.2	Inferred	Crafted probes are sent and a match with response patterns e.g TTL or handshake behaviour to a fingerprint database, a probable match is given rather than a direct read
Service characteristics	Ubuntu explicitly referenced in Apache service banners	Figure 4.1 which shows the ubuntu being explicitly stated	Observed	Directly shown within service version strings in Figure 4.1
Other fingerprinting evidence	Network distance 1 hop	Network distance 1 hop as seen in figure 5.1	Observed	Directly shown in the figure 5.1

5.2 OS Fingerprinting importance in penetration testing

It allows a penetration tester to narrow down which vulnerabilities, exploits and attack techniques are applicable to the target given that different operating systems and kernel versions have different weaknesses and default configurations. Additionally, it assists in validating findings from other stages of assessment e.g for example service banners suggesting an ubuntu build align with the Linux operating system conclusion thus increasing the overall confidence in the target's technical profile.

5.3 Importance of validating fingerprinting results

The OS scan infers the OS by matching observed network behaviour against a database rather than carrying out a direct reading. This makes the result uncertain as shown in figure 5.1 where the kernel range rather than the exact version was provided. Cross referencing of the results against Independently observed evidence e.g service banners, allows for one to achieve a much more accurate end result rather than automatically trusting the initial result.

Chapter 6: WEB FOOTPRINTING

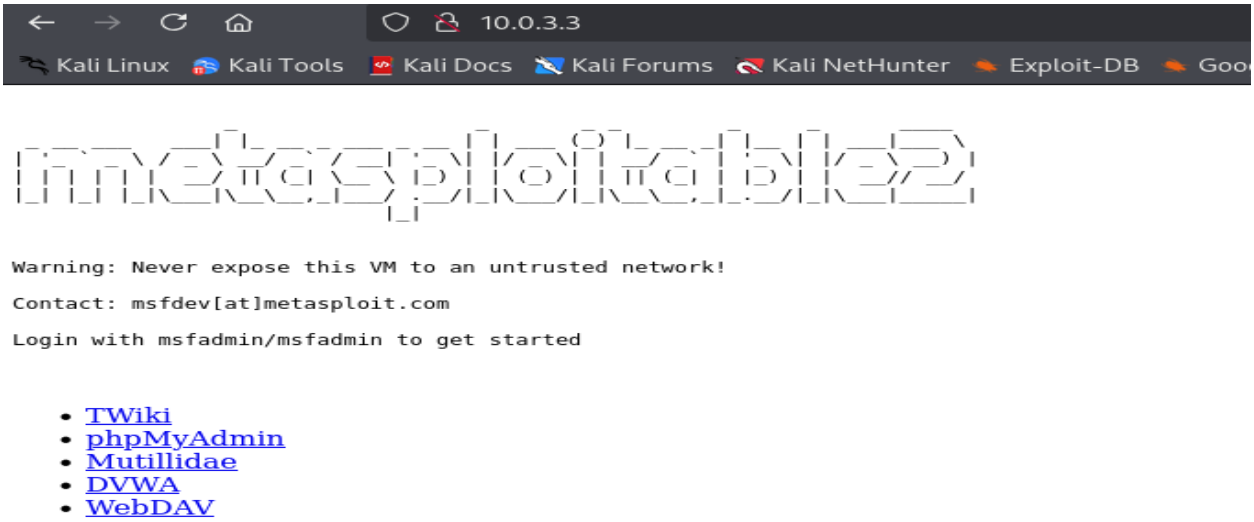


Figure 6.1 Web Service

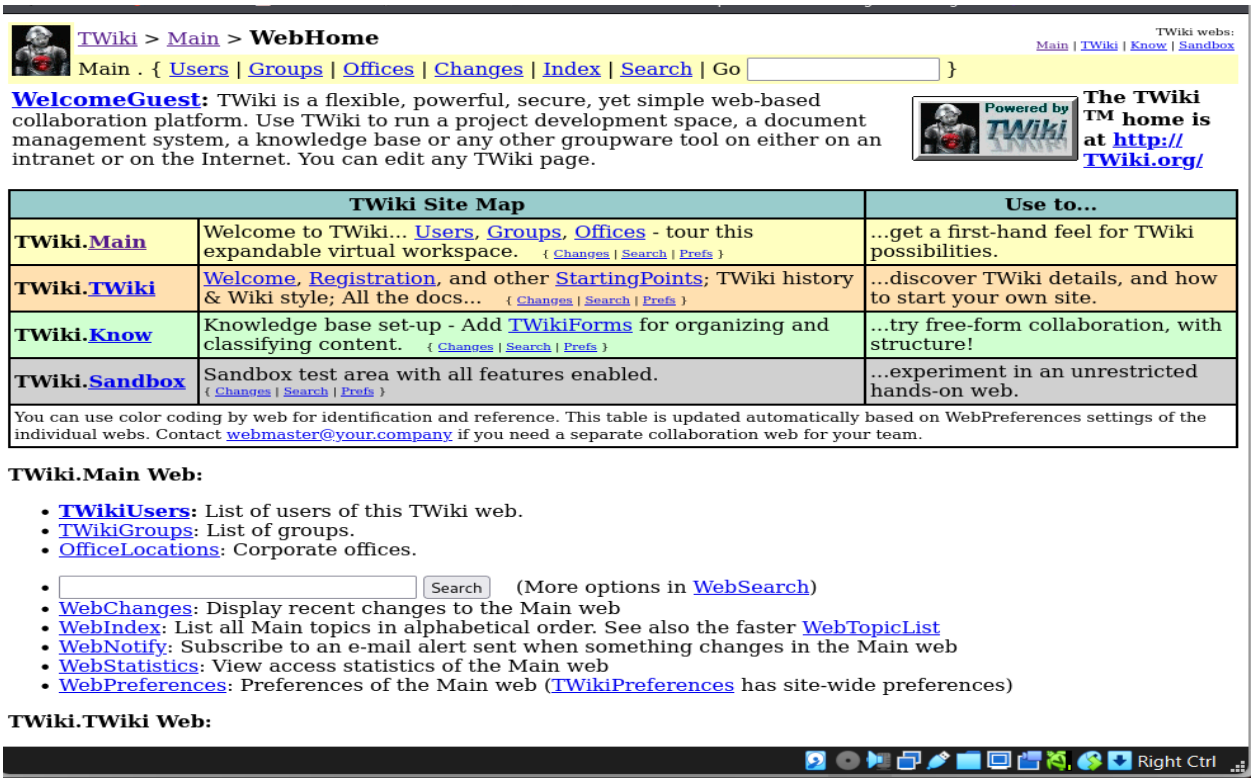


Figure 6.2 TWIKI platform



Figure 6.3 Mutillidae platform

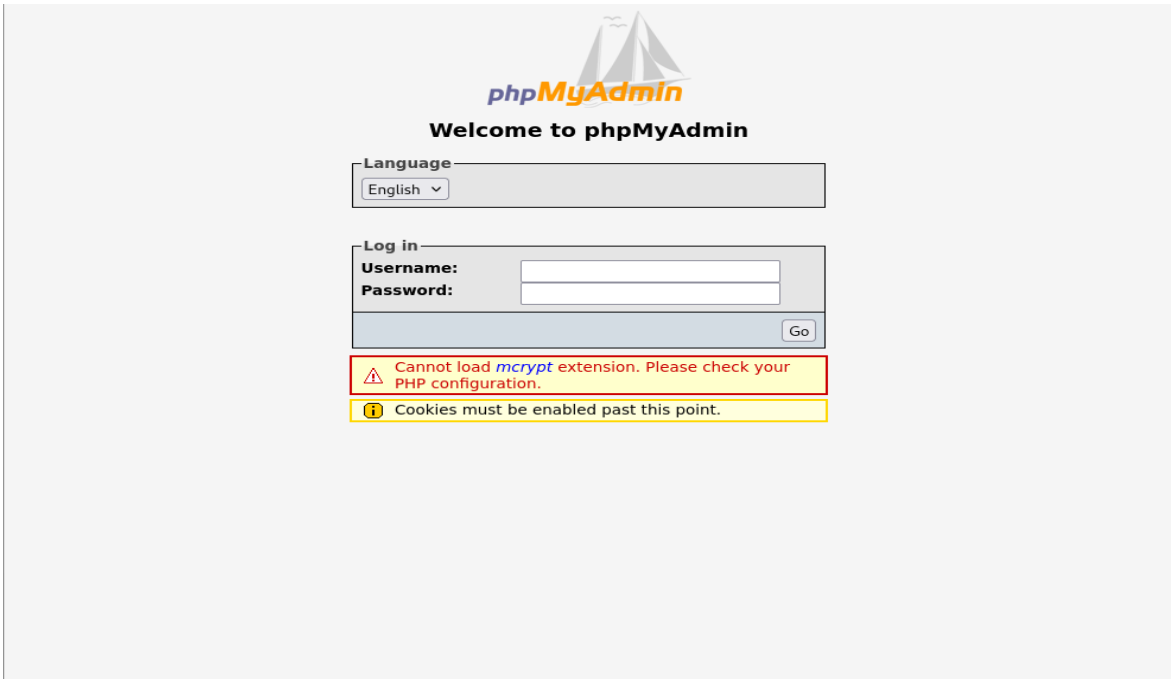


Figure 6.4 PhpMyAdmin

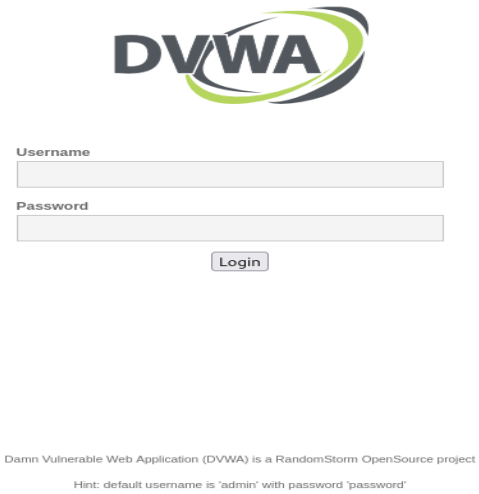


Figure 6.5 Vulnerable Web Application

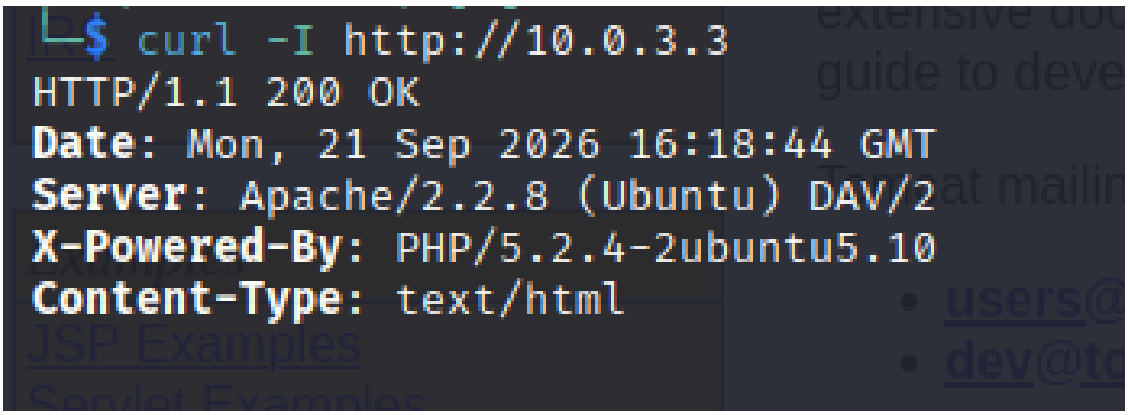


Figure 6.6 HTTP header request

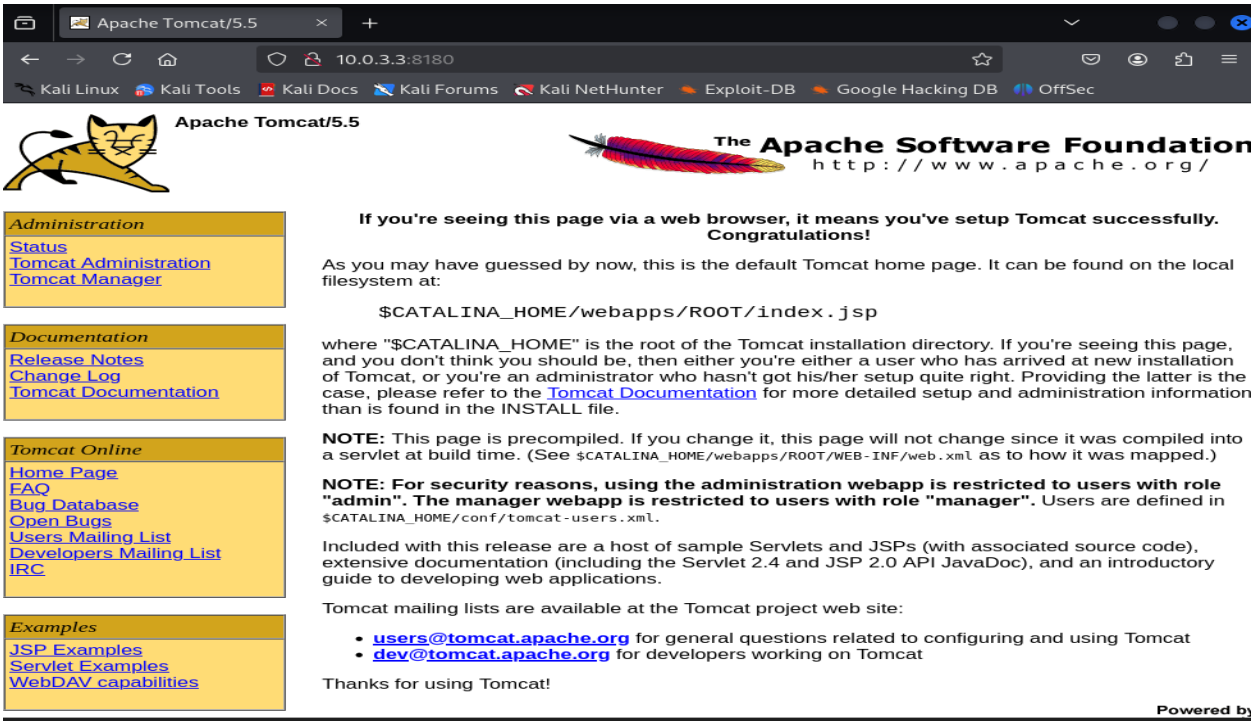


Figure 6.7 Tomcat's Home page

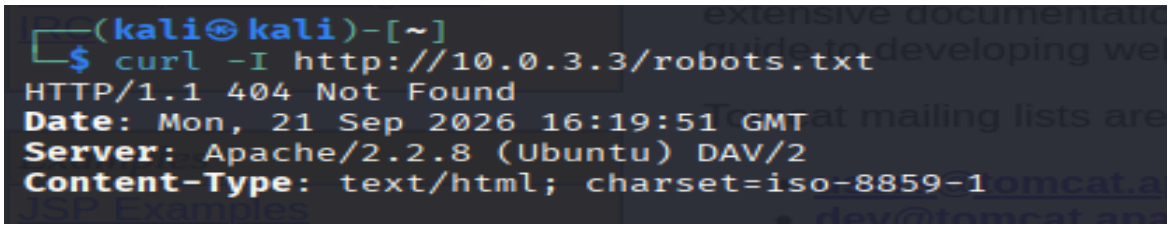


Figure 6.8 Absent robot's exclusion file

6.1 Web Service Identification

When carrying out enumeration, web services were confirmed to be exposed on both port 80 (primary web server) and port 8180 (Apache Tomcat) Browsing to http://10.0.3.3 returned the target machine's home page as shown in Figure 6.1 and http://10.0.3.3:8180 returned Tomcat's default page showing that both services are live and accessible via http.

6.2 Web Server Fingerprinting

A HTTP header request as shown in figure 6.5 using the curl command, returned explicit server and technology information i.e Apache/2.2.8 (Ubuntu) DAV/2 and X-Powered-By: PHP 5.2.4-2ubuntu5.10 which in turn confirms the web serve software and version as well as the OS distribution, the enabled WebDav module and scripting language PHP version 5.2.4.

6.3 Application Discovery

The homepage shown in figure 6.1 lists five linked applications i.e TWIKI, phpMyAdmin,DVWA, Mutillidae and WebDAV. Four were accessed during the assessment.

- TWiki- as shown in figure 6.2, it is a platform that exposes a full site map, userlist references and administrative links
- Mutillidae – a deliberately vulnerable PHP training application that covers OWASP Top 10 vulnerability classes as shown in figure 6.3.
- DVWA(Damn Vulnerable Web Application) – a vulnerable sql application with a login interface as shown in figure 6.5
- PhpMyAdmin – A web based database administration platform as shown in figure 6.4 displaying a warning on an extension that may be missing.

6.4 Application Entry Points

TWiki provides multiple interactive links e.g Users , Groups and search without an authentication barrier as shown in figure 6.9 one can click users and get some information

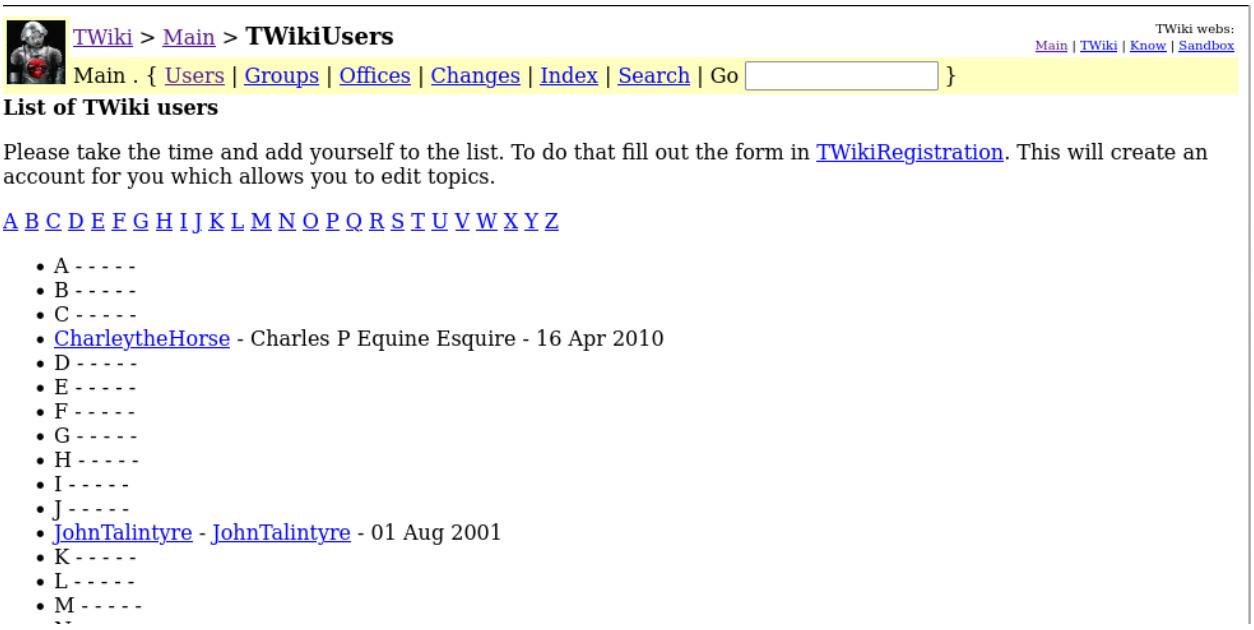


Figure 6.9 List of Twiki Users

DVWA shows the default publicly disclosed credentials which allows access to the server as an administrator as seen in figure 6.5. Tomcat's homepage exposes links to an Administartion and Manager interface as seen in Figure 6.7. PhpMyAdmin discloses server side configuration errors indicating outdated configurations.

6.5 Information disclosure

The homepage discloses the user and password as seen in Figure 6.1. The mutillidae application discloses the exact interface's version. DVWA's login page discloses default application credentials in a visible hint. HTTP response headers disclose the exact server, OS, and language version as seen in Figure 6.6. A request to /robots.txt returned the 404 error as shown in figure 6.8 indicating no directory hints were obtained. The PhpMyAdmin 's login page discloses a server-side misconfiguration error indicating an outdated configuration as seen in Figure 6.4.

6.6 Web Attack Surface

The combination of the multiple vulnerable applications, an outdated web server ,a disclosed web server/PHP stack, and a separate Tomcat application platform with exposed admin interfaces increases the attack surface. This is because each application represents a distinct entry point with its own vulnerabilities. Additionally the lack of authentication on Twiki nd the exposure of default credentials on DVWA lowers the effort for unauthorized access. Ultimately this increases the risk making it easier for the attacker to exploit these vulnerabilities.

Chapter 7: ATTACK SURFACE MAPPING AND PRIORITIATION

7.1 Attack Surface Map

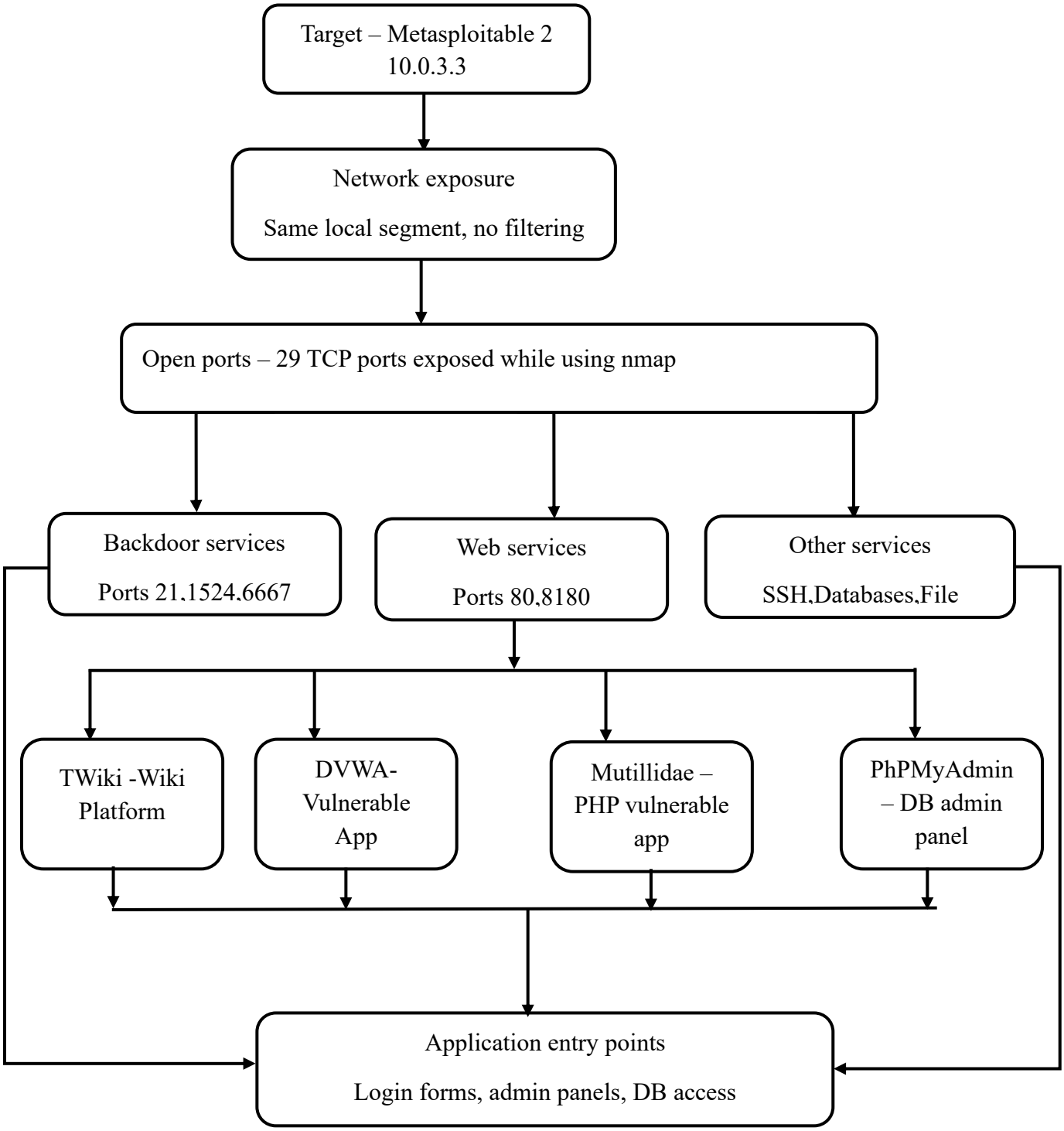


Figure 7.1 Attack Surface Map

7.2 Prioritization

Port 1524 – Unauthenticated root bindshell

As seen in Figure 4.1, Nmap identified this port as Metasploitable root shell. This port was considered as a strong candidate due to the fact that it provides unauthenticated root-level access which grants an attacker all rights to alter any information or carry out malicious activities on the machine. The next step of investigation would be a formal vulnerability confirmation and exploitation testing which is out of this assessment's scope, followed by an immediate shutdown of the port as a remedy.

Port 21 – vsftpf 2.3.4 (known backdoor)

As disclosed by the service banner in figure 4.1 for port 21,, this port was considered to require the greatest attention due to its publicly documented vulnerability of a back door i.e CVE-2011-2523. The next step of investigation would be vulnerability research and confirmation testing.

Port 23 -telnet

As shown in Figure 4.1, the port is open and the service is confirmed to be running via the service banner. This port was selected since it transmits all session data including credentials in plaintext. Any attacker who tries to carry out packet sniffing can obtain this information directly without any challenge due to no network layer filtering as seen with the single hop. The next step would be to disable the port completely and rely on the use of SSH version 2 for remote administration.

Chapter 8: SECURITY ANALYSIS AND RECOMMENDATIONS

8.1 USEFUL INFORMATION TO AN ATTACKER

Information that would be most useful to an attacker would be the vulnerable ports that are open e.g telnet on port 23 which means an attacker can carry out a man in the middle attack. Additionally the service versions shown through banner grabbing, especially those with documented vulnerabilities such as vsftpd 2.3.4 on port 21, UnreallRCD on port 6667 and the unauthenticated bindshell on port 1524. The exact version numbers enable an attacker to search public vulnerability databases for known exploits specific to the version. Furthermore, the aspect of no network layer filtering tells an attacker that scanning and exploitation traffic will reach the target without being dropped. In terms of the web services, the displayed credentials on the home website allows for an attacker to gain authenticated access using the provided admin credentials with no further effort.

8.2 APPLICATIONS REQUIRING THE GRATEST ATTENTION

Three findings stand out as demanding immediate action. The bindshell on port 1524 as seen in figure 4.1, is identified as Metasploitable root shell, which allows unauthenticated root access and represents the ,most crucial finding as it would allow an attacker to carry out admin privileges using this backdoor. The vsftpd 2.3.4 service on port 21 corresponds to the vsftpd version publicly documented with a backdoor vulnerability, which indicates that known exploit paths exist. Another key finding is the port 23 on which the telnet service is running on as seen in Figure 4.1 which has a known vulnerability of transmitting data and credentials in plain text hence an attacker can easily carry out a man in the middle attack to obtain the credentials amd reuse them to gain access. Beyond these three are the multiple database services that exist i.e MySQL and PostgreSQl which expose the database to the network and may be prone to database attacks. Filesharing services such as nfs and several intentionally vulnerable web applications such as DVWA collectively broaden the attack surface since a single compromise still leverages the rest due to lack of network segmentation.

8.3 MEASURES TO BE TAKEN BY AfriLink Digital

AfriLink should first disable the bindshell on port 1524 to prevent unauthenticated root access from being carried out followed by disabling telnet on port 23 and relying on SSH version 2 on port 22 to ensure encrypted remote access. Additionally, AfriLink should update their outdated software such as the vsftpd on port 21, UnreallRCd and Apache 2.2.8 to close known vulnerabilities. Introducing network segmentation or filtering to reduce the ease with which any

single exposed service can be reached directly to address the no filtering finding established by the evidence of a single hop.

CONCLUSION

This assessment was successful in creating a full footprint of the Metasploitable 2 target server using only reconnaissance activities as per the Rules of Engagement for this engagement. It is evident that the target server has been identified and its place within the network determined, 29 open ports and services were enumerated, the Operating System fingerprinted, and the web application attack surface mapped out on the five applications. Of significance to note are three findings that will require immediate remediation – an unauthenticated root bindshell, backdoor FTP service, and Telnet unsecured service. The total attack surface shows a history of accumulation of legacy systems with outdated and unpatched services, with some having deliberately added vulnerabilities. This assessment provides AfriLink Digital Services Ltd. with the foundation for proceeding to vulnerability confirmation and exploitation testing upon approval.

REFERENCES

Nmap.org. (n.d.). *Nmap Reference Guide*. Retrieved from https://nmap.org/book/man.html

National Vulnerability Database. (2011). *CVE-2011-2523: VSFTPD backdoor vulnerability*. Retrieved from https://nvd.nist.gov/vuln/detail/CVE-2011-2523

National Vulnerability Database. (2010). *CVE-2010-4221: ProFTPD remote code execution vulnerability*. Retrieved from https://nvd.nist.gov/vuln/detail/CVE-2010-4221

National Vulnerability Database. (2007). *CVE-2007-2447: Samba "usermap script" command injection vulnerability*. Retrieved from https://nvd.nist.gov/vuln/detail/CVE-2007-2447

National Vulnerability Database. (2004). *CVE-2004-2687: distcc remote code execution vulnerability*. Retrieved from https://nvd.nist.gov/vuln/detail/CVE-2004-2687

National Vulnerability Database. (2010). *CVE-2010-2075: UnrealIRCd backdoor vulnerability*. Retrieved from https://nvd.nist.gov/vuln/detail/CVE-2010-2075

Rapid7. (n.d.). *Metasploitable 2 documentation*. Retrieved from https://docs.rapid7.com/metasploit/metasploitable-2/

https://www.geeksforgeeks.org/ethical-hacking/ethical-hacking-footprinting/

https://www.geeksforgeeks.org/ethical-hacking/types-of-footprinting-in-ethical-hacking/

APPENDICES

Table Findings

ID	Finding	Evidence	Affected Component	Security Significance	Priority
F-01	Unauthenticated root bindshell active	Figure 4.1 (Nmap: "Metasploitable root shell")	Port 1524	Direct, unauthenticated root-level access to the host	Critical
F-02	vsftpd 2.3.4 with known backdoor vulnerability	Figure 4.1	Port 21 (FTP)	Publicly documented backdoor (CVE-2011-2523) enabling remote root access	Critical
F-03	UnrealIRCd with known backdoor vulnerability	Figure 4.1	Ports 6667/6697 (IRC)	Publicly documented backdoor (CVE-2010-2075)	Critical
F-04	Telnet service transmits credentials in plaintext	Figure 4.1	Port 23	Credentials interceptable via packet sniffing; no network filtering to prevent this (Section 3)	High
F-05	Default/disclosed credentials publicly visible	Figures 6.1, 6.5	Homepage, DVWA login page	msfadmin/msfadmin and DVWA admin/password hints lower barrier to unauthorized access	High

ID	Finding	Evidence	Affected Component	Security Significance	Priority
F-06	Outdated web server and scripting language	Figure 6.6 (HTTP headers)	Apache 2.2.8, PHP 5.2.4	Multiple known vulnerabilities associated with these outdated versions	Medium
F-07	Multiple intentionally vulnerable web applications exposed	Figures 6.1–6.5	DVWA, Mutillidae, TWiki, Phpmyadmin	Broadens web attack surface; each is an independent entry point	Medium
F-08	Legacy r-services suite exposed (rexec/rlogin/rsh)	Figure 4.1	Ports 512–514	Weak/no authentication, no encryption — obsolete protocol family	Medium
F-09	No network-layer filtering between assessment machine and target	Figures 3.2, 3.3	Network layer	Scan and attack traffic reaches target unobstructed, increasing reliability of any attack	Medium
F-10	Multiple database services exposed to network	Figure 4.1	Ports 3306 (MySQL), 5432 (PostgreSQL)	Potential sensitive data exposure if authentication is weak or misconfigured	Medium

Evidence Log

Table Evidence Logs

Evidence ID	Activity	Target	Observation	Evidence Location	Significance
E-01	Console login	10.0.3.3	Hostname "metasploitable" confirmed via login banner	Figure 2.1	Established target identity
E-02	Interface check	10.0.3.3	Target IP confirmed via ifconfig	Figure 2.2	Confirmed authorized target address

Evidence ID	Activity	Target	Observation	Evidence Location	Significance
E-03	Host discovery scan	10.0.3.3	Host up, reachable via ARP-based probe	Figure 3.1	Confirmed reachability
E-04	ICMP ping	10.0.3.3	TTL=64, replies received	Figure 3.2	Confirmed 0-hop local connectivity
E-05	Traceroute	10.0.3.3	Single hop returned	Figure 3.3	Confirmed no routing device present
E-06	ARP table check	Local network	MAC address 08:00:27:14:99:C6 mapped to target	Figure 3.4	Established unique host identifier
E-07	Vendor identification scan	10.0.3.3	NIC vendor identified as Oracle VirtualBox	Figure 3.5	Confirmed virtualized lab environment
E-08	Full port/version scan	10.0.3.3	29 open TCP ports identified with service/version data	Figure 4.1	Established full-service inventory
E-09	OS detection scan	10.0.3.3	Linux kernel 2.6.9–2.6.33 inferred	Figure 5.1	Established OS fingerprint
E-10	Web browsing	10.0.3.3:80	Homepage with 5 linked applications discovered	Figure 6.1	Identified web application attack surface
E-11	Web browsing	10.0.3.3 (TWiki)	Vulnerable PHP app, version 2.1.19 disclosed	Figure 6.2	Application discovery
E-12	Web browsing	10.0.3.3 (mutillidae)	Wiki platform with user/group references discovered	Figure 6.3	Application discovery

Evidence ID	Activity	Target	Observation	Evidence Location	Significance
E-13	Web browsing	10.0.3.3 (phpMyAdmin)	Login page with PHP config warning disclosed	Figure 6.4	Possible Misconfiguration identified
E-14	Web browsing	10.0.3.3 (DVWA)	Login form with disclosed default credentials	Figure 6.5	Information disclosure finding
E-15	HTTP header request	10.0.3.3:80	Apache 2.2.8, PHP 5.2.4 disclosed	Figure 6.6	Server fingerprinting
E-16	Web browsing	10.0.3.3:8180	Apache Tomcat 5.5 default page discovered	Figure 6.7	Additional web service identified
E-17	robots.txt check	10.0.3.3	404 Not Found	Figure 6.8	Negative finding, documented

Analytical Questions

1. Why should a penetration tester establish Rules of Engagement before conducting technical testing?
   This is because it protects both the penetration tester and client legally from unauthorized or unintended actions thus minimizing legal liability. Additionally, it gives the tester a clear reference point of the scope and stop conditions.

2. Which decisions did you make when developing your Rules of Engagement, and why were those decisions appropriate for this engagement?
   A specific testing window i.e early morning hours was chosen to minimize the risk of disrupting active users to ensure operations remain up and running by the time a user wants to use the system. Passive and active foot printing techniques were used since they were explicitly permitted since the assessment required active scanning while exploitation and credential use or modification was left out as Afri Link required a reconnaissance only.

3. What could happen if a penetration tester conducts reconnaissance without clearly defining the target and scope?
   A tester risks liability when testing unauthorized which could later lead to legal action even if accidental. It could also lead to time wastage due to investigation of irrelevant systems. Additionally, it could lead to loss of client trust if a client notices a discrepancy in their file due to an accidental modification.

4. Why is reconnaissance important before vulnerability identification and exploitation?

It is the core foundation on which later stages are dependent on since without knowing what services or ports an open, it would be more of a guessing game leading to time wastage and unintended disruption.

5. What is the difference between information gathering, enumeration, vulnerability identification and exploitation?
   Information gathering is the retrieval of a large amount of data on a target e.g network and host details. Enumeration on the other hand is the process of systematically identifying exposed services, ports and their characteristics. Vulnerability identification is the matching e.g of service versions against known vulnerabilities e.g the vsftpd 2.3.4 backdoor vulnerability. Exploitation is the active use of an identified vulnerability to attain unauthorized access.

6. How can service-version information influence the next stage of a penetration test?
   Exact service version enables testers to carry out a search on possible known vulnerabilities specific to that version thus shaping which exploitation technique they would use. It also assists in prioritizing effort as historically vulnerable versions such as vsftpd 2.3.4 cause for a more urgent follow up than a fully patched service.

7. Why should a penetration tester distinguish between an observed fact and an inference?
   An observed fact is directly confirmed evidence while an inference is a drawn conclusion from indirect evidence that carries a level of uncertainty. If one were to treat an inference as a confirmed fact, it risks later decisions such as which exploit to attempt an incorrect assumption. For example, an inferred assumption on the linux version being used being a certain version could lead to the wrong exploit being used as possibly the vulnerability on the assumed version has already been patched.

8. How can exposed services increase the attack surface of a server?
   Each exposed service creates a potential independent entry point for an attacker. The more entry points an attacker has the greater the attack surface this is because the more services a server exposes, the more likely there has to be vulnerability present. Additionally, some services tend to interact, e.g captured credentials from an unencrypted service could possibly be reused e.g to access a database.

9. How can web-server and application information assist an attacker during attack planning?

   Information such as exact software versions, frameworks, and enabled modules allow attackers to identify vulnerabilities specific to the exact configuration as shown by the Apache/PHP version disclosure. Additionally, entry points such as login forms, reveal where an attacker might attempt further attacks as found on this target thus eliminating the need to exploit.

10. Based on your findings, what information would you prioritize for further investigation and why?

    Four findings that were identified i.e the unauthenticated bindshell (port 1524), the vsftpd 2.3.4 backdoor (port 21), the telnet (port 23) and the UnreallRCd backdoor (port 6667) would be prioritized for further investigation as each corresponds to a strongly suspected vulnerability thus representing possible paths to a system's compromise.